

Manual 15 - Implementación Controlada de SOC 2

Authority boundary: original implementation guidance. SOC 2 is an independent CPA attestation examination, not a certification.

Localized editions are controlled implementation translations and are not AICPA-authorized translations. The controlled English edition governs interpretation.

Manual 15 — Localization and Artifact Handoff

****State:**** controlled pre-publication preparation; not publication authorization

****Series order:**** 15

****Controlling English source blob:****
`92bd8eb8b51dbd1367e4968eaf3fad1b399af5d9`

****Controlling source:****
`English/source/CONTROLLED\_CHAPTERS\_01\_32.md`

Objective

Move Manual 15 from completed controlled English source into exact-source localization and publication-candidate preparation without changing the authoritative interpretation boundary or fabricating human semantic review.

Exact-source rule

All es-419 and pt-BR localized drafts must derive from the English source blob identified above. If the English source changes materially, localization parity and all downstream artifact hashes are invalidated and must be regenerated from the new exact source.

English remains the controlling interpretation. Localized editions are implementation translations and must not be described as AICPA-authorized or official translations.

Mandatory terminology boundaries

Preserve these distinctions in both localized editions:

- SOC 2 is an independent CPA attestation examination/reporting engagement, not a certification.
- Trust Services Criteria and Description Criteria are separate controlled concepts.
- Management owns the system description, assertion, controls, evidence and remediation; the independent practitioner owns examination procedures, professional judgment, opinion and report issuance.
- Type 1 and Type 2 readiness must remain distinct.
- Security, availability, processing integrity, confidentiality and privacy must remain separate categories where applicable.
- Complementary user-entity controls and subservice-organization responsibilities must not be collapsed into service-organization controls.
- Readiness assistance must never be represented as replacing independent CPA judgment.

es-419 controlled-draft requirements

Use professional Latin American Spanish suitable for GRC, audit, privacy, security and executive readers. Retain `SOC 2`, `Trust Services Criteria`, `Description Criteria`, `Type 1`, `Type 2` and other formal identifiers where translation could imply a different official term. Use consistent controlled equivalents for system description, assertion, service organization, subservice organization, complementary user-entity controls, evidence population, operating effectiveness, exception, remediation and reassessment.

The es-419 draft may be machine-assisted, but substantive semantic acceptance must be recorded separately if repository policy requires genuine human judgment.

pt-BR controlled-draft requirements

Use professional Brazilian Portuguese suitable for GRC, auditoria, privacidade, segurança and executive readers. Retain formal SOC identifiers where translating them could imply an official AICPA translation. Use consistent controlled equivalents for system description, assertion, service organization, subservice organization, complementary user-entity controls, evidence population, operating effectiveness, exception, remediation and reassessment.

The pt-BR draft may be machine-assisted, but substantive semantic acceptance must be recorded separately if repository policy requires genuine human judgment.

Parity QA

Before artifact generation, fail closed unless all three editions satisfy:

1. exactly 32 chapters in identical order;
2. equivalent chapter purpose and control/evidence intent;
3. no dropped management/practitioner independence boundary;
4. no new certification, endorsement or legal-compliance claim introduced by translation;
5. no omission of owners, frequencies/triggers, populations, evidence, exceptions/remediation or reassessment concepts where present in English;
6. no stale source lineage;
7. no protected AICPA criteria text reproduced beyond permissible use.

Publication-candidate generation

After trilingual source/parity QA, generate six candidate binaries from the exact controlled sources:

- EN DOCX and PDF;
- es-419 DOCX and PDF;
- pt-BR DOCX and PDF.

The generator must create reproducible metadata, language tags, headings, page numbering, controlled-use notice and source/provenance references. PDFs must undergo text-content preflight and rendered accessibility/visual review. DOCX/PDF files must not be resaved after SHA-256 binding.

Provenance and durability

For each candidate record:

- source path and source blob/commit;
- artifact path;
- SHA-256;
- generation workflow/run identifier;
- page/content QA result;
- accessibility/visual result;
- terminology/parity result;
- review evidence required by repository policy;
- predecessor publication state.

Validated binaries must then be durably staged to the repository without regeneration. Catalog and work-product release-registry changes occur only after all publication gates are satisfied.

Current blocker boundary

Manual 14 is published, so predecessor order is satisfied. Manual 15 is not publication-eligible until controlled es-419 and pt-BR editions, exact candidate artifacts, rendered/accessibility QA, checksum/provenance, durable artifact staging, and any explicitly required genuine-human substantive reviews are complete. Standing Final Human Release Approval remains separate and does not substitute for genuine-human review where repository policy explicitly requires it.

Manual 15 — Implementación Controlada de SOC 2

Aviso de uso controlado

Este manual es una guía original de implementación y preparación. No reproduce los Trust Services Criteria, los Description Criteria, guías pagadas, informes ilustrativos ni material reservado para profesionales de AICPA. SOC 2 es un examen de atestiguamiento independiente realizado por un CPA; no es una certificación. La administración es responsable del sistema, los controles, la descripción del sistema, las afirmaciones, la evidencia y la remediación; el profesional independiente es responsable de los juicios del examen y del informe.

Esta edición es una traducción de implementación controlada en español latinoamericano (es-419) y no es una traducción oficial ni autorizada por AICPA. La edición controlada en inglés prevalece para fines de interpretación.

Chapter 01 — Propósito, audiencia y contexto del encargo

Use este manual para establecer un modelo repetible de preparación SOC 2 y operación de controles y evidencia. Defina por qué la organización necesita un informe SOC 2, los usuarios previstos, los servicios involucrados, el calendario esperado, el tipo de informe probable y las categorías de Trust Services relevantes. Designe un patrocinador ejecutivo, responsable de preparación, propietario de la descripción del sistema, propietarios de controles, proveedores de evidencia, responsables de remediación y participantes legales, de privacidad y tecnología. Mantenga un registro de decisiones sobre alcance, criterios, tipo de informe, tratamiento de subservice organizations, supuestos significativos y cambios.

La evidencia debe incluir el requerimiento de negocio, estatuto de preparación, RACI, hitos, criterios de selección del auditor, registro de decisiones y el límite documentado entre apoyo de preparación y juicio independiente del CPA.

Chapter 02 — Límite de la organización de servicios y definición del sistema

Defina la organización de servicios y el sistema que entrega los servicios dentro del alcance. Identifique infraestructura, software, datos, personas, procedimientos, ubicaciones físicas, servicios en la nube, procesos de desarrollo y soporte, identidades, servicios de monitoreo y terceros materiales. Parta de los compromisos con clientes y de la entrega real del servicio, no de un perímetro técnico conveniente.

Mantenga una declaración de alcance, inventario de componentes, diagramas de arquitectura y flujo de datos, catálogo de servicios, registros de propiedad, mapa de dependencias y reevaluación activada por cambios. Toda exclusión debe tener justificación documentada y análisis de impacto.

Chapter 03 — Responsabilidades de la administración y afirmación

La administración es responsable de diseñar, implementar, operar, monitorear y describir los controles, así como de realizar las representaciones requeridas para el encargo. Asigne ejecutivos responsables y propietarios operativos de controles, establezca responsabilidades sobre evidencia y exija revisión de la administración sobre deficiencias significativas, incidentes, excepciones y cambios en la descripción del sistema.

No delegue la responsabilidad de la administración a un consultor de preparación ni al auditor de servicios. Conserve aprobaciones, representaciones de la administración, atestaciones de propietarios de controles, decisiones sobre hallazgos y evidencia de que la administración comprende el sistema y el entorno de control que describe.

Chapter 04 — Descripción del sistema y preparación frente a Description Criteria

Construya la descripción del sistema a partir de hechos operativos verificables. Describa los servicios, límites del sistema, infraestructura, software, personas, procedimientos, datos, compromisos significativos, eventos significativos, controles aplicables, subservice organizations y responsabilidades complementarias de user entities. Mantenga separadas las afirmaciones de marketing de las declaraciones de aseguramiento.

Use un proceso controlado de elaboración con propietario, colaboradores, historial de versiones, vínculos a evidencia, puntos de revisión y activadores de cambio. Reconcilie la descripción con arquitectura, contratos,

inventarios, políticas, incidentes y evidencia operativa real antes del trabajo de campo del examen.

Chapter 05 — Estructura de Trust Services Criteria y mapeo controlado

Trate los Trust Services Criteria aplicables como criterios de aseguramiento, no como una lista de tecnologías prescritas. Comience con compromisos, requisitos del sistema, riesgos y objetivos de control y después mapee los controles implementados a identificadores de criterios aplicables utilizando referencias legalmente permitidas. Security es fundamental; availability, processing integrity, confidentiality y privacy se incluyen cuando correspondan al encargo.

Mantenga una matriz criterio-riesgo-control que registre propietario, actividad de control, frecuencia, población, evidencia, enfoque de prueba, excepciones y activadores de cambio. Los points of focus pueden orientar la implementación, pero no deben presentarse como controles obligatorios independientes salvo que la guía autorizada exija ese tratamiento.

Chapter 06 — Modelo de implementación de Security/common criteria

Construya un entorno integrado de controles de seguridad que cubra gobierno, evaluación de riesgos, comunicación, acceso, operaciones, monitoreo, cambio, respuesta a incidentes, dependencias de proveedores y acciones correctivas. Los controles deben conectarse con riesgos reales y compromisos del sistema y operar de forma consistente durante el período correspondiente.

Para cada control de seguridad, documente propósito, propietario, procedimiento, frecuencia o activador, límite del sistema o población, fuente de evidencia, revisor, ruta de excepción y activador de reevaluación. Evite controles duplicados que generen evidencia contradictoria o responsabilidad poco clara.

Chapter 07 — Modelo de implementación de Availability

Cuando availability esté dentro del alcance, traduzca los compromisos de servicio en controles de capacidad, resiliencia, respaldo, recuperación, monitoreo, incidentes y continuidad. Defina objetivos medibles y dependencias que respalden los compromisos de la organización sin implicar garantías que no puedan evidenciarse.

Conserve tendencias de capacidad, resultados de monitoreo, objetivos de recuperación, evidencia de respaldos, pruebas de restauración, ejercicios de continuidad, registros de incidentes, evidencia de niveles de servicio, riesgos de dependencias y acciones correctivas. Reevalúe el diseño después de cambios importantes de arquitectura, proveedor, carga de trabajo o compromisos.

Chapter 08 — Modelo de implementación de Processing Integrity

Cuando processing integrity sea relevante, defina controles que respalden procesamiento autorizado, completo, exacto, oportuno y válido conforme a los compromisos del sistema. Aborde validación de entradas, lógica de procesamiento, interfaces, manejo de errores, conciliaciones, monitoreo de trabajos, transformaciones de datos, controles de salida y cambios controlados.

La evidencia debe demostrar la población de procesamiento definida, detección de excepciones, conciliación, corrección, autorización, monitoreo e historial de cambios. No atribuya processing integrity únicamente a la disponibilidad de la aplicación o a controles genéricos de seguridad.

Chapter 09 — Modelo de implementación de Confidentiality

Identifique la información designada como confidencial por compromisos, contratos, políticas o necesidad de negocio y mapee cómo se clasifica, accede, transmite, almacena, comparte, conserva y elimina. Aplique controles proporcionales a la sensibilidad y a los requisitos contractuales.

Mantenga inventarios de datos, reglas de clasificación, registros de acceso, evidencia de cifrado y gestión de claves cuando aplique, controles de transferencia, calendarios de retención, evidencia de eliminación, responsabilidades de proveedores y registros de excepciones. Mantenga confidentiality separada de privacy incluso cuando la misma información sea confidencial y personal.

Chapter 10 — Modelo de implementación de Privacy

Cuando privacy esté dentro del alcance, defina cómo se gobierna la información personal durante la recolección, aviso, elección o consentimiento cuando corresponda, uso, acceso, divulgación, retención, corrección, eliminación, seguridad, calidad y monitoreo. Mapee

compromisos de privacidad y requisitos del sistema a controles operativos sin tratar SOC 2 como sustituto del análisis de cumplimiento legal.

Mantenga inventarios de datos, avisos, registros de atención de solicitudes, evidencia de retención y eliminación, registros de compartición, gobierno de procesadores y subprocesadores, procedimientos de incidentes, capacitación, quejas y resultados de monitoreo. Las interpretaciones legales corresponden a profesionales legales o de privacidad calificados.

Chapter 11 — Evaluación de riesgos y diseño de controles

Opere un proceso documentado de riesgos que considere objetivos, compromisos, amenazas, vulnerabilidades, fraude, cambios tecnológicos, terceros, privacidad, disponibilidad, cadena de suministro de software, identidad, dependencias operativas e incidentes previos. Defina criterios de riesgo, propietarios, decisiones de tratamiento, umbrales de aprobación y activadores de reevaluación.

Conecte cada riesgo material con controles o una decisión explícita de tratamiento. La evidencia debe mostrar identificación, análisis, justificación del diseño del control, aceptación o remediación, propiedad, fechas objetivo, historial de revisiones y vínculo con cambios del sistema.

Chapter 12 — Gobierno y gestión de políticas

Cree una estructura de gobierno que haga visible la propiedad de controles y convierta las políticas en requisitos operativos. Cada política o estándar controlado debe tener propietario, aprobador, versión, fecha de vigencia, fecha de revisión, requisito de distribución o capacitación, proceso de excepción y controles operativos mapeados.

Use revisiones recurrentes de la administración para abordar evidencia vencida, excepciones, incidentes, fallas de control, cambios de alcance, problemas con proveedores y antigüedad de remediaciones. La aprobación de una política por sí sola no constituye evidencia operativa; conserve prueba de que las actividades requeridas realmente ocurrieron.

Chapter 13 — Acceso lógico y ciclo de vida de identidades

Gobierne identidades de empleados, contratistas, terceros, privilegiadas, de servicio, de aplicación y de máquina desde la solicitud hasta la eliminación. Defina diseño de roles, mínimo privilegio, procesos de altas/cambios/bajas,

aprobaciones, aprovisionamiento, revisiones periódicas, manejo de cuentas inactivas y retención de evidencia.

Mantenga poblaciones completas desde sistemas de identidad autoritativos cuando sea posible. La evidencia debe vincular solicitudes, aprobaciones, aprovisionamiento, cambios, revisiones, bajas y excepciones con identidades y períodos específicos. Reevalúe los controles de acceso después de cambios organizacionales, de plataforma o autenticación.

Chapter 14 — Acceso privilegiado y MFA

Trate el acceso privilegiado como un dominio de riesgo separado. Inventaríe roles y cuentas administrativas, restrinja su asignación, use autenticación robusta, controle accesos de emergencia, proteja credenciales y secretos, registre actividad privilegiada cuando corresponda y revise autorizaciones y uso.

La evidencia debe incluir poblaciones de cuentas privilegiadas, aprobaciones, configuración de MFA, revisiones de acceso, registros de bóvedas o gestión de secretos cuando aplique, registros de acceso de emergencia, resultados de monitoreo y revocación oportuna. El acceso privilegiado compartido o no administrado requiere remediación explícita o tratamiento de riesgo.

Chapter 15 — Operaciones del sistema y monitoreo

Defina procedimientos operativos para servicios de producción, herramientas de seguridad, trabajos, interfaces, capacidad, alertas, incidentes, mantenimiento y revisiones rutinarias. Identifique cobertura requerida de monitoreo, propietarios, umbrales, rutas de escalamiento, retención de evidencia y manejo de fallas.

Conserve paneles operativos o exportaciones, registros de alertas o casos, resultados de trabajos, evidencia de mantenimiento, tickets de problemas, registros de escalamiento y métricas de gestión. El monitoreo debe demostrar respuesta a condiciones relevantes, no solo que una herramienta está habilitada.

Chapter 16 — Gestión de vulnerabilidades y configuración

Mantenga inventarios y expectativas aprobadas de configuración para los componentes dentro del alcance. Opere procesos de descubrimiento de vulnerabilidades, evaluación, priorización, remediación, excepción, nueva prueba y métricas adecuados al entorno.

La evidencia debe vincular hallazgos con activos afectados, propietarios, decisiones de riesgo, fechas objetivo, correcciones, nuevas pruebas y excepciones. La evidencia de configuración debe mostrar aprobación de líneas base, estado de implementación, historial de cambios, tratamiento de desviaciones y verificación periódica. La salida del escáner por sí sola no demuestra remediación efectiva.

Chapter 17 — Respuesta a incidentes y recuperación

Mantenga un programa de respuesta a incidentes con severidad definida, roles, escalamiento, investigación, contención, preservación de evidencia, comunicaciones, recuperación, lecciones aprendidas y acciones correctivas. Integre eventos cibernéticos, de privacidad, disponibilidad, proveedores y operaciones cuando sean relevantes para el sistema.

Pruebe el plan mediante ejercicios y conserve escenarios, participantes, resultados, brechas, acciones y evidencia de cierre. Los incidentes materiales deben activar reevaluación de riesgos, controles, exactitud de la descripción del sistema, compromisos, dependencias de proveedores y revelaciones del examen.

Chapter 18 — Gestión de cambios y ciclo de vida de desarrollo seguro

Exija autorización trazable, análisis de riesgo e impacto, pruebas, revisión, aprobación de despliegue, planificación de reversión y verificación posterior al cambio para cambios materiales. Integre requisitos de seguridad, remediación de vulnerabilidades, gestión de dependencias, revisión de código, controles CI/CD, límites de acceso a producción y manejo de cambios de emergencia según corresponda.

La evidencia puede incluir tickets, pull requests, aprobaciones, resultados de pruebas, logs de despliegue, registros de releases, revisiones de emergencia y controles de segregación de funciones. Preserve la población completa de cambios necesaria para muestreo de Type 2 y reconcíliela con sistemas fuente.

Chapter 19 — Logging, alertas y retención de evidencia

Defina qué sistemas y actividades de control requieren logs, alertas, pistas de auditoría y evidencia retenida. Establezca expectativas de recolección, sincronización de tiempo, acceso, retención, revisión, escalamiento e integridad según riesgo del sistema y necesidades del encargo.

Mantenga inventarios de fuentes, configuraciones de retención, logs representativos, casos de alertas, evidencia de revisión, registros de acceso y manejo de excepciones. Los repositorios de evidencia deben proteger información confidencial y preservar procedencia, permitiendo a la vez acceso autorizado del auditor por canales controlados.

Chapter 20 — Respaldo, resiliencia y monitoreo de disponibilidad

Defina alcance, frecuencia, protección, retención y pruebas de restauración de respaldos, mecanismos de resiliencia, dependencias y monitoreo operativo. Alinee el diseño de recuperación con compromisos de servicio documentados e impacto al negocio, no con objetivos genéricos.

Conserve poblaciones de trabajos de respaldo, manejo de fallas, evidencia de pruebas de restauración, ejercicios de resiliencia o failover, monitoreo de capacidad y disponibilidad, acciones de recuperación y remediación. Un respaldo exitoso no demuestra recuperabilidad si la restauración no se valida periódicamente.

Chapter 21 — Gobierno de proveedores y subservice organizations

Inventaríe terceros y subservice organizations que hospeden, procesen, soporten, protejan o afecten materialmente al sistema dentro del alcance. Defina diligencia debida, clasificación de riesgo, contratación, mapeo de responsabilidades, revisión de aseguramiento, monitoreo, escalamiento de incidentes, gestión de cambios y controles de terminación.

Conserve contratos y términos de seguridad, registros de diligencia debida, informes de aseguramiento, bridge letters o actualizaciones equivalentes cuando sean relevantes, hallazgos, consideraciones complementarias de subservice organizations, cambios de servicio, incidentes y remediación. Reevalúe dependencias cuando cambien la arquitectura o los servicios.

Chapter 22 — Complementary user-entity controls

Identifique controles o responsabilidades que se espera que las user entities ejecuten para que los controles y compromisos de la organización de servicios operen según lo previsto. Vincule cada complementary user-entity control con el límite de servicio correspondiente, el mecanismo de comunicación y el supuesto asociado.

La administración debe asegurar que estas responsabilidades estén descritas y comunicadas con precisión y evitar usarlas para trasladar responsabilidad de controles que realmente pertenecen a la organización de servicios. Mantenga evidencia de identificación, revisión, comunicación al cliente y reconciliación con la descripción del sistema.

Chapter 23 — Nube y consideraciones de responsabilidad compartida

Mappee servicios en la nube, plataformas administradas, dependencias SaaS, controles heredados, controles configurados por el cliente, identidades, logging, gestión de claves, límites de red, ubicaciones de datos y responsabilidades de proveedores. Documente dónde la responsabilidad es compartida y dónde la organización de servicios debe producir su propia evidencia.

Use los informes de aseguramiento de proveedores como insumos de evidencia, no como prueba automática de que la configuración o responsabilidades de la organización son efectivas. Conserve inventarios de servicios, matrices de responsabilidad, evidencia de configuración, revisiones de aseguramiento de proveedores, excepciones y activadores de cambio.

Chapter 24 — Operaciones de privacidad y ciclo de vida de datos

Operacionalice el gobierno de datos personales mediante inventarios, mapeo de propósitos y compromisos, controles de acceso, calendarios de retención, eliminación, compartición, manejo de solicitudes, procesos de incidentes, controles de proveedores y monitoreo. Reconcilie las operaciones de privacidad con el sistema real y los compromisos con clientes.

La evidencia debe basarse en poblaciones cuando sea posible y mostrar oportunidad, aprobaciones, resultados, excepciones y acciones correctivas. Mantenga separadas las conclusiones de cumplimiento legal de la evidencia de preparación SOC 2 y remita la interpretación específica de jurisdicción a profesionales calificados.

Chapter 25 — Población de evidencia y preparación para muestreo

Para controles recurrentes, preserve poblaciones completas y reproducibles desde fuentes autoritativas. Defina cómo se generan, reconcilian, protegen y

vinculan las poblaciones con el período del examen. Evite listas seleccionadas manualmente que excluyan fallas o carezcan de procedencia.

Cada objeto de evidencia debe identificar sistema fuente, método de consulta o reporte, propietario, período, tamaño de población, contexto de selección, artefacto retenido, revisor y excepciones. Las decisiones de muestreo corresponden al profesional; la responsabilidad de la administración es proporcionar evidencia completa y exacta y explicar cómo se produjo.

Chapter 26 — Preparación Type 1 versus Type 2

Un modelo de preparación Type 1 se enfoca en si los controles están adecuadamente diseñados e implementados a una fecha especificada. Un modelo Type 2 también debe soportar evidencia de operación de controles durante el período correspondiente. Confirme el tipo de informe previsto con el profesional independiente y con los requisitos de clientes y negocio.

Para Type 2, construya calendarios de evidencia antes de que comience el período, preserve poblaciones recurrentes, monitoree actividades omitidas y remedie temprano. No reconstruya ni complete retroactivamente evidencia de manera que tergiverse cuándo o cómo operó un control.

Chapter 27 — Gobierno de excepciones, desviaciones y remediación

Defina cómo se registran, evalúan, asignan, remedian, vuelven a probar y escalan las excepciones de control, brechas de evidencia, desviaciones, incidentes y hallazgos de pruebas. Distinga brechas aisladas de documentación de fallas de diseño u operación basándose en evidencia y no en conveniencia.

Mantenga identificadores de problemas, controles o poblaciones afectados, impacto, causa raíz cuando sea práctico, propietario, fecha objetivo, tratamiento interino, evidencia de remediación, resultado de nueva prueba, análisis de recurrencia y decisiones de la administración. No elimine elementos fallidos de la población para mejorar el desempeño aparente.

Chapter 28 — Revisión de la administración y monitoreo continuo

Opere revisiones de la administración durante todo el año usando indicadores de salud de controles, completitud de evidencia, antigüedad de excepciones, incidentes, cambios de proveedores, resultados de revisiones

de acceso, tendencias de vulnerabilidades, pruebas de recuperación, revisiones de políticas y cambios del sistema. Defina umbrales de escalamiento y derechos de decisión.

Conserve actas o aprobaciones equivalentes, paneles, excepciones, decisiones, aceptaciones de riesgo, compromisos de remediación y evidencia de seguimiento. El monitoreo continuo apoya la preparación pero no reemplaza las pruebas ni el juicio del profesional.

Chapter 29 — Interacción con auditor y gestión de solicitudes

Seleccione una firma CPA independiente adecuadamente calificada y establezca comunicación controlada, transferencia de evidencia, seguimiento de solicitudes, hitos, discusiones de alcance, escalamiento de problemas y manejo de confidencialidad. La administración debe proporcionar información exacta y revelar problemas relevantes conocidos, en vez de optimizar entregables únicamente por apariencia.

Mantenga un registro de solicitudes con propietario, fecha de vencimiento, artefacto, estado, preguntas, seguimiento y resolución. El personal de preparación puede organizar evidencia y explicar procesos, pero no dirigir ni limitar procedimientos o conclusiones independientes del profesional.

Chapter 30 — Lectura del informe, salvedades y hallazgos

Prepare a la administración y a usuarios autorizados para leer el informe final en contexto: alcance del servicio o sistema, criterios y categorías, período o fecha, tratamiento de subservice organizations, complementary user-entity controls, pruebas, excepciones, respuestas de la administración y cualquier salvedad o limitación. Evite reducir el informe a una insignia binaria.

Dé seguimiento a hallazgos y excepciones hasta la remediación y reevaluación. Las declaraciones externas sobre el estado SOC 2 deben ser exactas, actuales, consistentes con restricciones contractuales y de uso del informe y nunca implicar certificación ni aseguramiento más amplio que el contenido del informe.

Chapter 31 — Cumplimiento continuo y activadores de cambio

Mantenga la preparación entre exámenes mediante operación recurrente de controles, recolección de evidencia, revisión de riesgos, monitoreo de proveedores, gobierno de acceso, gestión de vulnerabilidades y configuración, pruebas de recuperación, revisión de políticas y remediación de problemas. Defina activadores que requieran reevaluación de alcance, controles, descripción del sistema o procesos de evidencia.

Ejemplos incluyen adquisiciones, productos nuevos, migraciones importantes a nube, rediseño de autenticación, nuevos procesadores, incidentes significativos, interrupciones materiales, nuevos compromisos, cambios de arquitectura y automatización de controles. Registre decisiones de impacto y asegure que los procedimientos de evidencia cambien con el sistema.

Chapter 32 — Release, reevaluación y ciclo de vida de evidencia

Antes de considerar el manual controlado listo para publicación, verifique el estado de fuentes autoritativas de AICPA, complete el maestro exacto en inglés, derive borradores controlados es-419 y pt-BR de esa fuente exacta, ejecute QA estructural, de copyright, terminología y paridad, genere candidatos exactos DOCX/PDF, ejecute QA renderizada de accesibilidad, visual y contenido, almacene binarios durables, registre procedencia SHA-256, reconcilie metadatos del ciclo de vida y confirme la publicación del predecesor.

Para uso organizacional, defina reglas de retención de evidencia, confidencialidad, transferencia segura, versionado, supersesión y reevaluación. No publique evidencia confidencial de clientes, datos de empleados, secretos, capturas de producción ni workpapers de auditoría restringidos en ejemplos públicos. Los cambios materiales reabren las puertas afectadas en vez de arrastrar silenciosamente evidencia obsoleta.

Referencias autoritativas

- Superficie temática y de recursos SOC 2 de AICPA & CIMA.
- AICPA & CIMA 2017 Trust Services Criteria (With Revised Points of Focus — 2022), utilizado solo como referencia autoritativa de criterios y no reproducido aquí.
- AICPA & CIMA 2018 SOC 2 Description Criteria (With Revised Implementation Guidance — 2022), utilizado solo como referencia autoritativa de descripción y no reproducido aquí.

- AICPA & CIMA SOC for Service Organizations Engagements — Overview, actualizado el 23 de abril de 2026.

La verificación de fuentes al momento del release sigue siendo obligatoria porque los estándares y la guía autoritativa pueden cambiar.